

Data Flow Diagram

for

Website Vulnerability Scanner

Prepared by

Deepthi K (241IT021)

Jasmine (241IT051)

Sacheth Koushal (241IT058)

Department of Information Technology
National Institute of Technology Karnataka, Surathkal

August 2026

Contents

1	Data Flow Diagram (DFD) Model	2
1.1	Level 0 DFD	2
1.1.1	Context Diagram	2
1.2	Level 1 DFD	2
1.2.1	Top-Level Functional Decomposition	2
1.3	Level 2 DFDs	4
1.3.1	0.1 User Authentication & Access Control	4
1.3.2	0.2 Target Management & Authorisation	5
1.3.3	0.3 Scan Configuration & Execution	6
1.3.4	0.4 Discovery (Crawling)	6
1.3.5	0.5 Vulnerability Detection	8
1.3.6	0.6 Findings Management	8
1.3.7	0.7 Reporting & Export	10
1.3.8	0.8 Safety, Auditing & Administration	10
2	Data Dictionary	12
2.1	Data Stores	12
2.2	Major Data Flows	13
3	Core Modules	14
3.1	0.1 User Authentication & Access Control	14
3.2	0.2 Target Management & Authorisation	14
3.3	0.3 Scan Configuration & Execution	14
3.4	0.4 Discovery (Crawling)	14
3.5	0.5 Vulnerability Detection	14
3.6	0.6 Findings Management	14
3.7	0.7 Reporting & Export	15
3.8	0.8 Safety, Auditing & Administration	15
4	Structure Charts	15
4.1	Level 1 Structure Chart	15
4.1.1	Module Decomposition	15

1 Data Flow Diagram (DFD) Model

1.1 Level 0 DFD

1.1.1 Context Diagram

Figure 1 shows the Level 0 Context Diagram for the Website Vulnerability Scanner system. It defines the main system boundary for Process 0 and models all inbound/outbound interaction channels with main external entities such as the WVS User, System Administrator, Target Website, Public DNS Resolvers, SMTP Relay, and OSV/EPSS Advisory APIs.

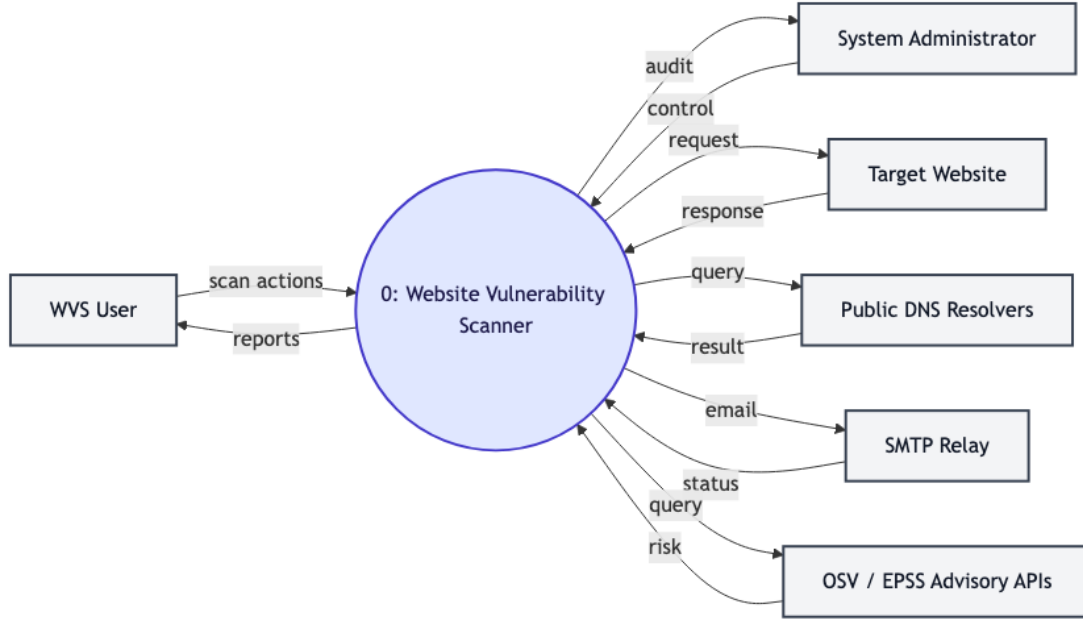


Figure 1: Level 0 Context Diagram

1.2 Level 1 DFD

1.2.1 Top-Level Functional Decomposition

Figure 2 shows the Level 1 DFD. Process 0 is decomposed into 8 primary functional modules (0.1 through 0.8). It displays the main scanning pipeline from the initial user request through scope validation, discovery crawling, vulnerability detection, findings management, and report generation, as well as centralized Scope Guard enforcement (0.8) and third-party integrations.

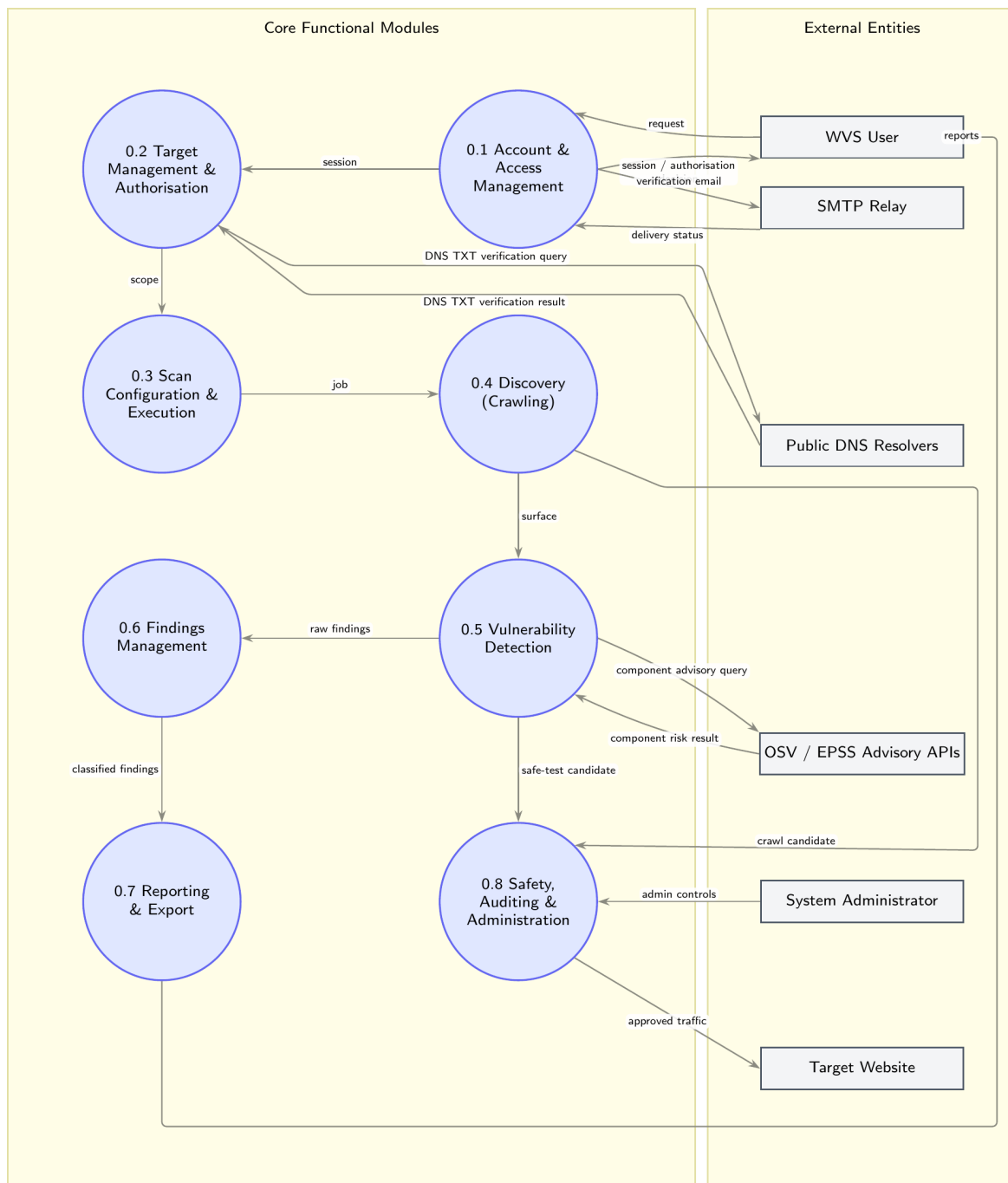


Figure 2: Level 1 DFD with 8 functional groups

1.3 Level 2 DFDs

1.3.1 0.1 User Authentication & Access Control

Process 0.1 is decomposed into credential validation, session token issuance, and login audit logging. Process 0.1.1 validates the user credentials by sending a verification request to Process 0.1.2 and saves the account and failed attempts in Data Store D1, Process 0.1.2 then issues session tokens and verifies email deliverability via SMTP Relay, and Process 0.1.3 records authentication audits.

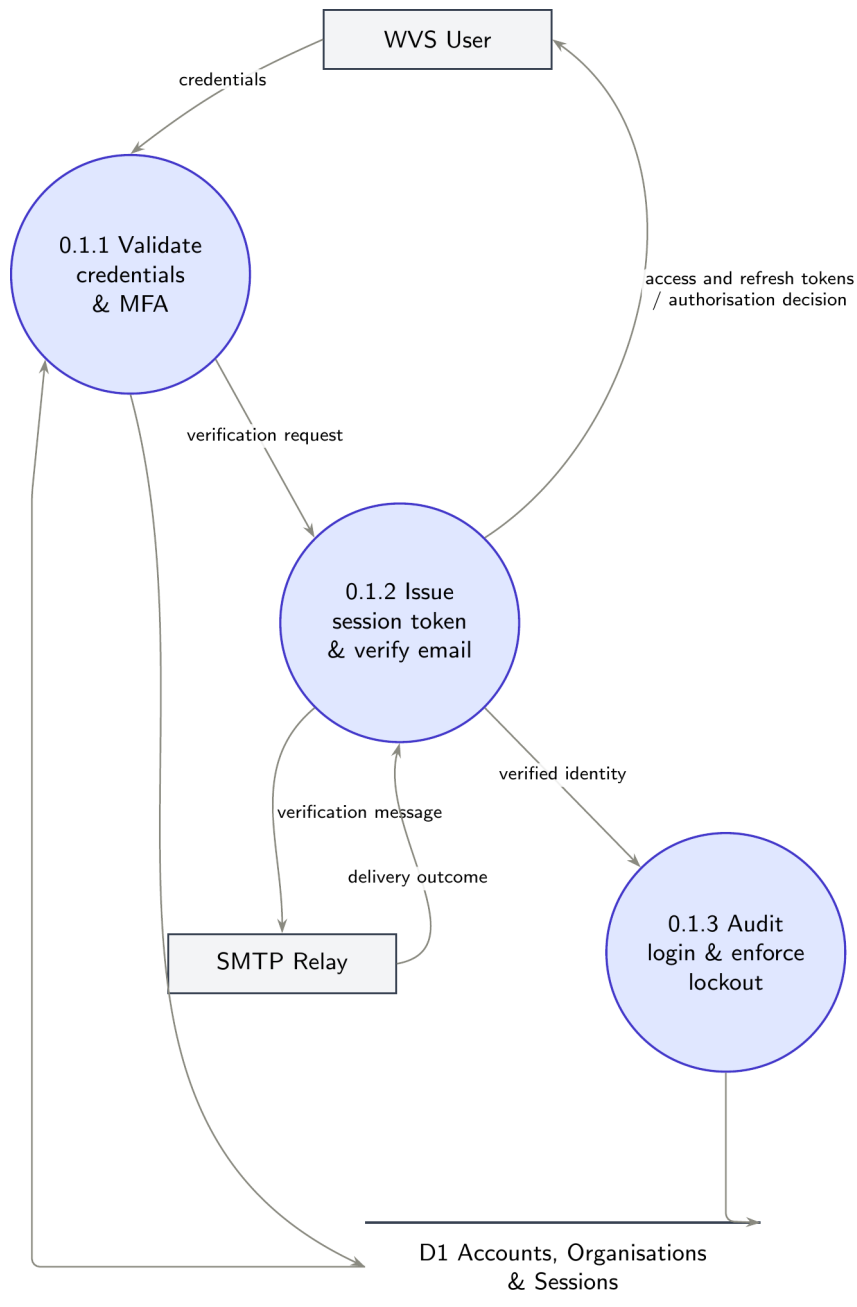


Figure 3: Level 2 DFD for 0.1 User Authentication & Access Control

1.3.2 0.2 Target Management & Authorisation

Process 0.2 is decomposed into target registration, verification token generation, and DNS/well-known proof validation. Process 0.2.1 registers target records in D2, Process 0.2.2 issues verification tokens for TXT/well known path validation and Process 0.2.3 validates these tokens against Public DNS and the Target Website.

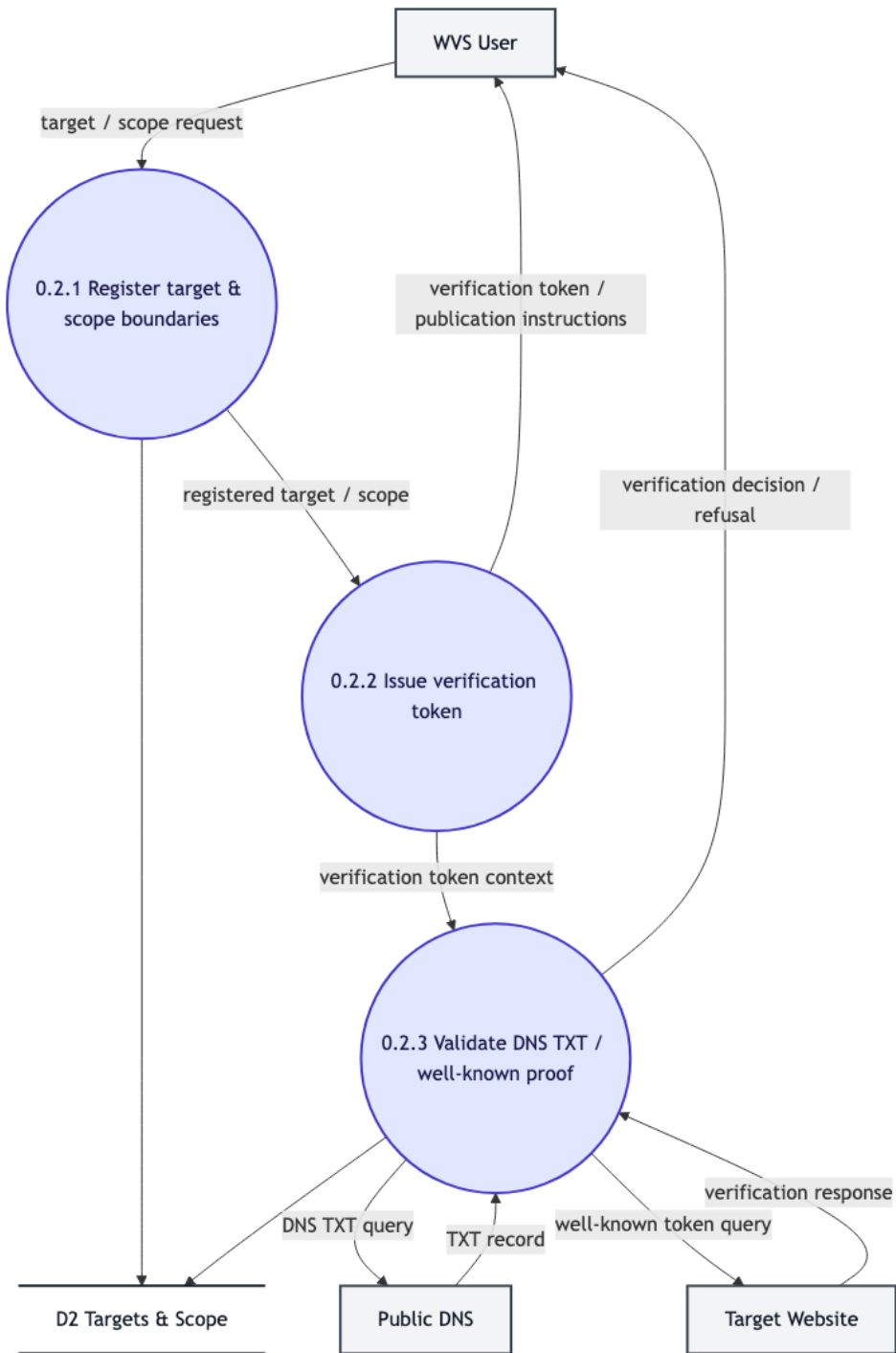


Figure 4: Level 2 DFD for 0.2 Target Management & Authorisation

1.3.3 0.3 Scan Configuration & Execution

Process 0.3 is decomposed into scan profile validation, job scheduling, and lifecycle execution. Process 0.3.1 verifies user scope and quotas against D2 and Process 0.3.2 queues scan jobs in D3, and Process 0.3.3 executes the scan lifecycle while writing reproducibility records to D4.



Figure 5: Level 2 DFD for 0.3 Scan Configuration & Execution

1.3.4 0.4 Discovery (Crawling)

Process 0.4 is decomposed into scope loading, link/form discovery, and JS rendering deduplication. Process 0.4.1 loads ceilings from D2, Process 0.4.2 sends crawl candidates to Process 0.8 Scope Guard, and Process 0.4.3 records page inventory in D4 upon receiving HTTP responses from the

Target Website.

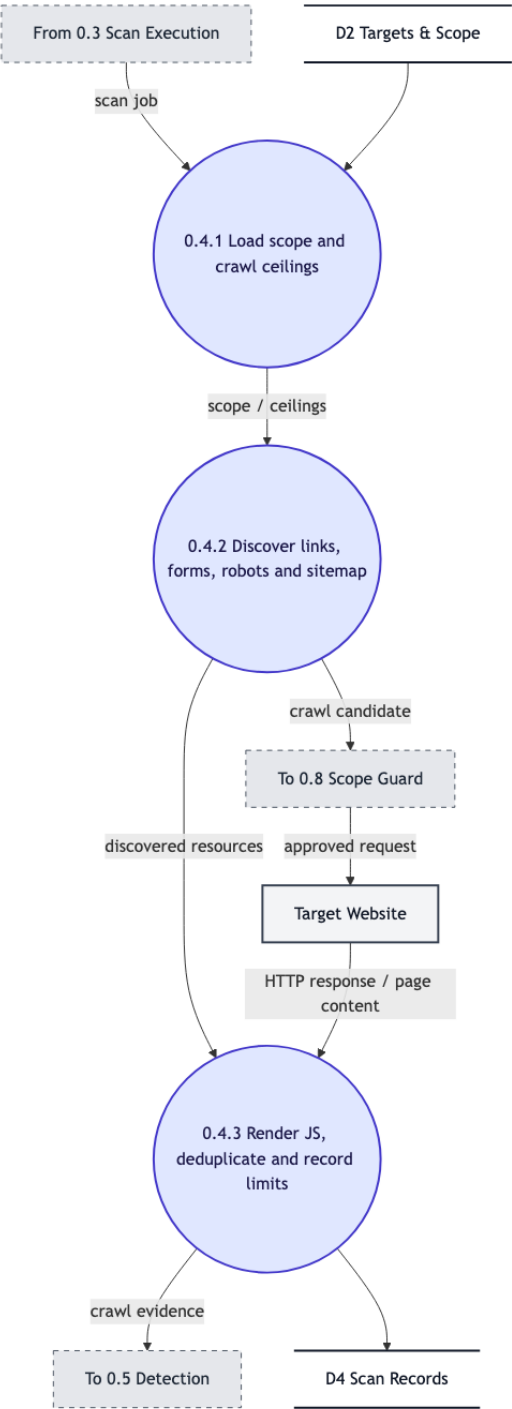


Figure 6: Level 2 DFD for 0.4 Discovery (Crawling)

1.3.5 0.5 Vulnerability Detection

Process 0.5 is decomposed into passive header checking, safe active test preparation, and advisory version enrichment. Process 0.5.1 runs passive analysis, Process 0.5.2 routes active test payloads through Process 0.8 Scope Guard, and Process 0.5.3 queries OSV/EPSS APIs and stores evidence in D5.

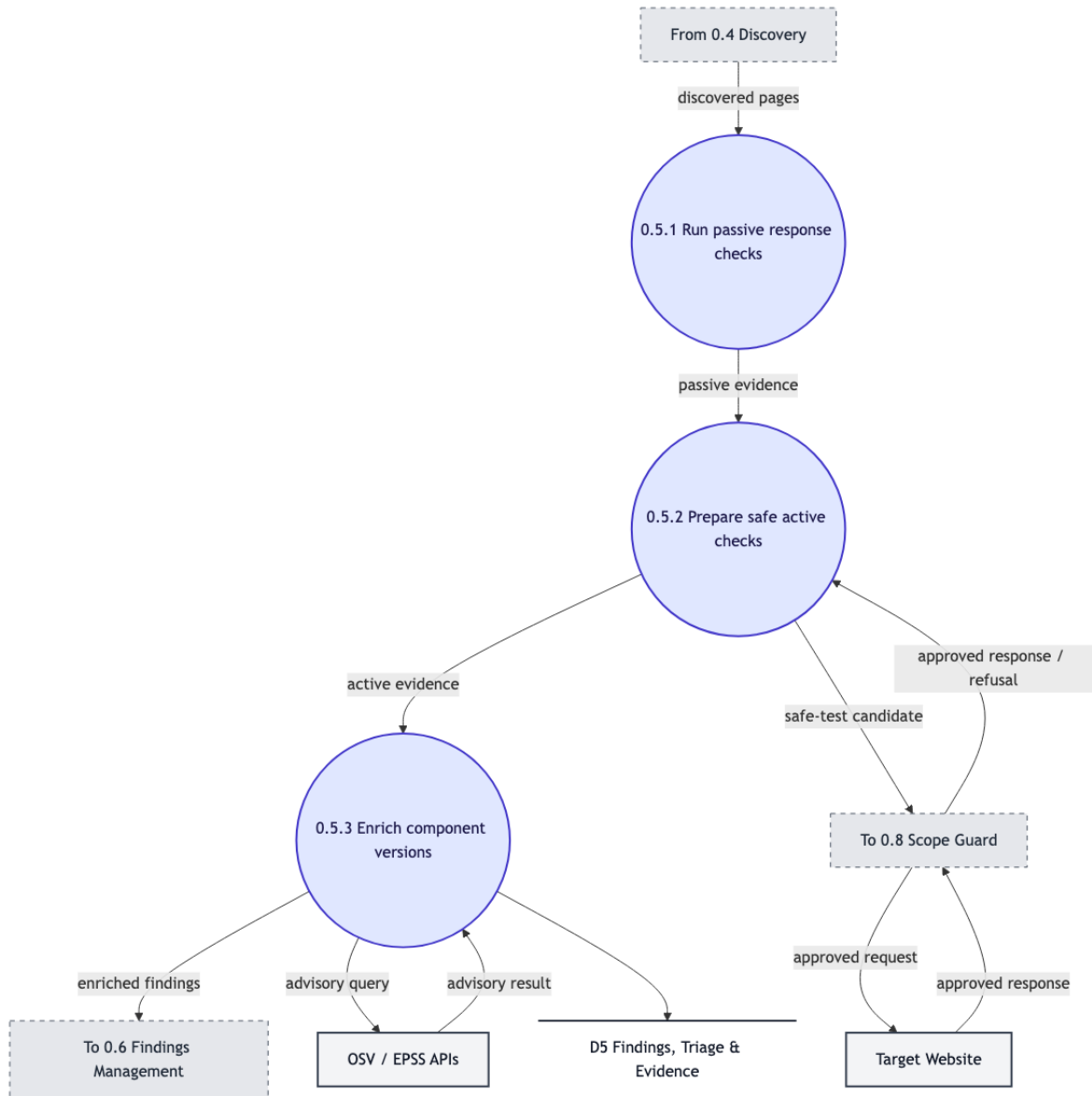


Figure 7: Level 2 DFD for 0.5 Vulnerability Detection

1.3.6 0.6 Findings Management

Process 0.6 is decomposed into normalisation/redaction, prior scan comparison, evidence retention and triage filtering. Process 0.6.1 ingests raw findings, normalises, redacts and deduplicates them. Process 0.6.2 compares prior scans stored in D5 and retains evidence, and Process 0.6.3 applies user triage, filters and sorts them and also implements severity classification.

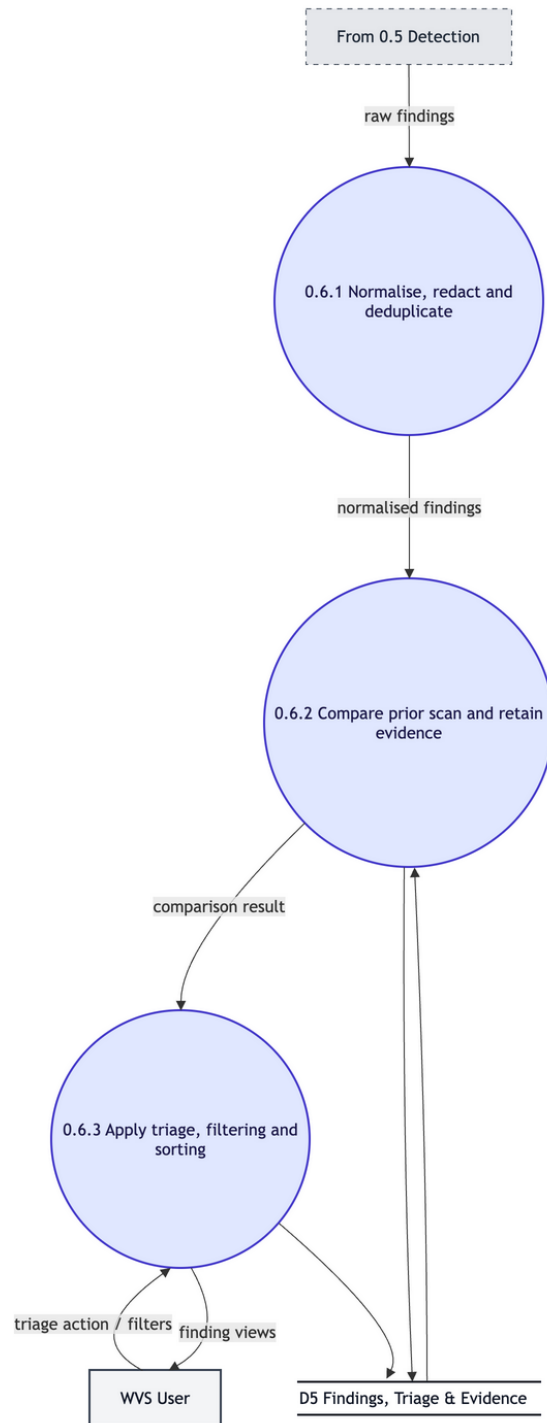


Figure 8: Level 2 DFD for 0.6 Findings Management

1.3.7 0.7 Reporting & Export

Process 0.7 is decomposed into completed scan selection, report template assembly, and export dispatch. Process 0.7.1 retrieves scan metadata from D4, Process 0.7.2 assembles the template, filters and limitations and the findings, triage and evidence from D5, and Process 0.7.3 generates export files (PDF/CSV) and triggers SMTP notifications.

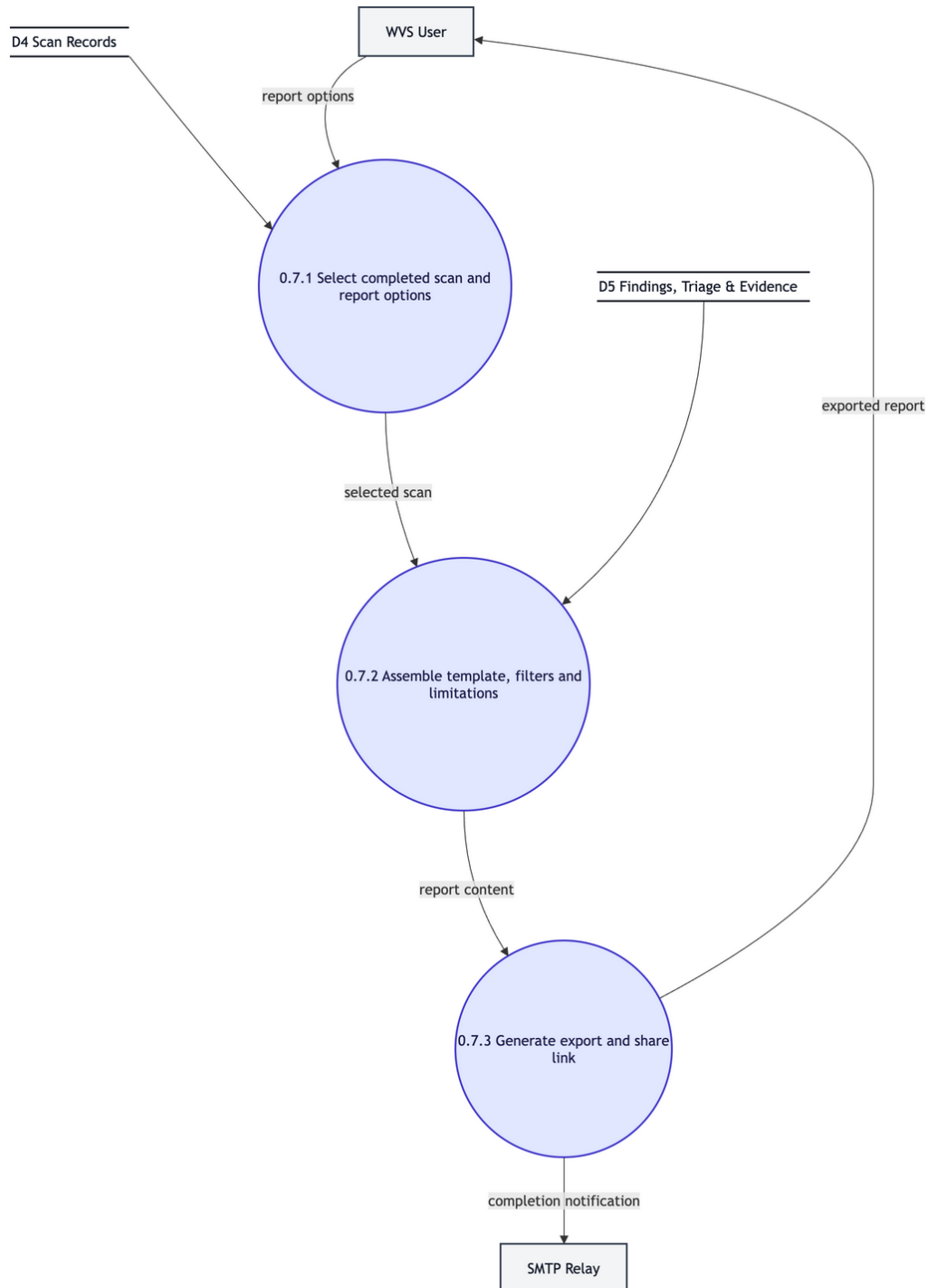


Figure 9: Level 2 DFD for 0.7 Reporting & Export

1.3.8 0.8 Safety, Auditing & Administration

Process 0.8 is decomposed into scope/blocklist verification, IP re-resolution & rate limiting, and request dispatch. Process 0.8.1 checks requests against D2 policies. Process 0.8.2 performs fresh

DNS checks to prevent SSRF, and Process 0.8.3 logs dispatches to D6 Append-only Audit Ledger.

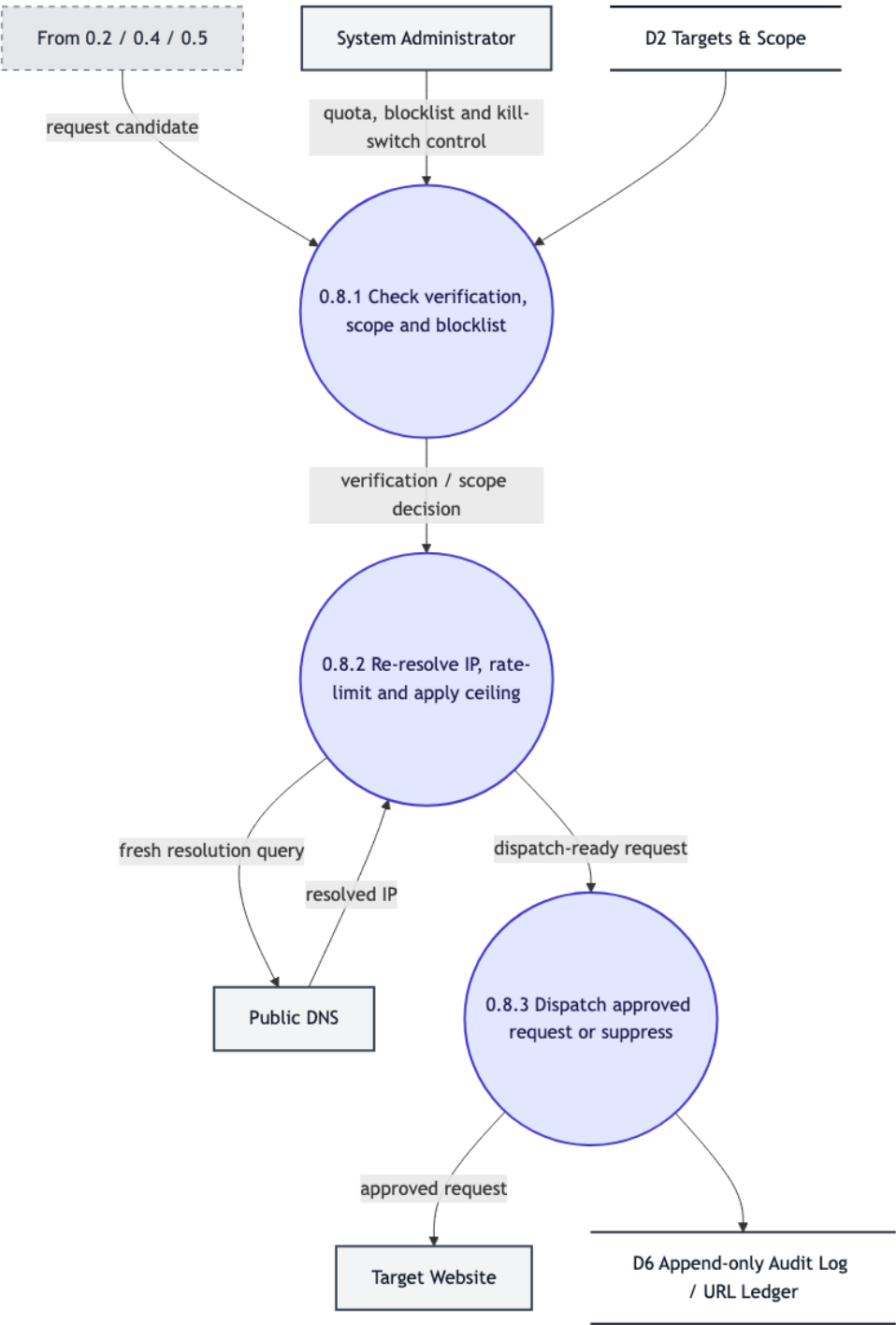


Figure 10: Level 2 DFD for 0.8 Safety, Auditing & Administration

2 Data Dictionary

The data dictionary formally defines the data stores and principal data flows of the DFD model. Each data store is described by its contents and the subprocesses that access it, and each major flow is described by its source, destination, and contents.

2.1 Data Stores

ID	Name	Contents / Schema Description	Related Sub-processes
D1	Accounts, Organisations & Sessions	User credentials, password hashes, MFA keys, organisation memberships, active JWT tokens, and failed login attempt counters.	0.1 (F.1)
D2	Targets & Scope	Target domain registrations, verified IP ranges, URI path inclusion/exclusion rules, ownership verification tokens, and scan ceilings.	0.2 (F.2), 0.3 (F.3), 0.4 (F.4), 0.8 (F.8)
D3	Jobs & Checkpoints	Queued scan jobs, worker assignments, execution state, pause checkpoints, and schedule cron triggers.	0.3 (F.3)
D4	Scan Records	Executed scan metadata, crawled page inventory, HTTP request/response headers, and crawl limits.	0.3 (F.3), 0.4 (F.4), 0.7 (F.7)
D5	Findings, Triage & Evidence	Detected vulnerability records, CVSS scores, raw HTTP request/response payloads, triage states (open/false positive/resolved), and historical scan comparison metadata.	0.5 (F.5), 0.6 (F.6), 0.7 (F.7)
D6	Append-only Audit Log / URL Ledger	Immutable cryptographic audit log recording all outbound HTTP requests, timestamped Scope Guard evaluations, admin kill-switch events, and URL dispatches.	0.8 (F.8)

2.2 Major Data Flows

Data Flow	Source	Destination	Description
request	WVS User	0.1 Account Management	Authentication credentials, login requests, or session refresh requests.
session	0.1 Account Management	0.2 Target Management	Authenticated user session and organisation permission context.
scope	0.2 Target Management	0.3 Scan Configuration	Verified target scope, path boundaries, and scan authorisation.
job	0.3 Scan Configuration	0.4 Discovery	Configured scan job payload ready for execution.
surface	0.4 Discovery	0.5 Detection	Crawled attack surface (discovered URLs, forms, headers, JS assets).
raw findings	0.5 Detection	0.6 Findings Management	Un-redacted vulnerability candidate evidence and response payloads.
classified findings	0.6 Findings Management	0.7 Reporting & Export	Deduplicated, triaged, and severity-classified vulnerability records.
reports	0.7 Reporting & Export	WVS User	Generated PDF/HTML reports, CSV exports, or share links.
crawl candidate	0.4 Discovery	0.8 Scope Guard	Candidate HTTP request generated during crawling for safety check.
safe-test candidate	0.5 Detection	0.8 Scope Guard	Active test request payload submitted for safety check before dispatch.
approved traffic	0.8 Scope Guard	Target Website	Validated HTTP request dispatched to target server within allowed rate limits.

3 Core Modules

This section explains the main functional modules of the Website Vulnerability Scanner. Each module is responsible for a specific part of the scanning process, from user login and target verification to vulnerability detection and report generation.

3.1 0.1 User Authentication & Access Control

This module manages user login, account registration, organisation onboarding, active sessions, and multi-factor authentication. It also helps protect user accounts by tracking login attempts and restricting access after repeated failures.

- **Functions:** Register users, verify login credentials and MFA, generate session tokens (JWT), record login activity, and apply account lockout when required.

3.2 0.2 Target Management & Authorisation

This module allows users to register the websites or domains they want to scan and define the permitted scanning scope. It also verifies that the user has permission to scan the target using DNS TXT records or well-known verification files.

- **Functions:** Register targets and scan scope, generate verification tokens, validate DNS TXT or well-known proofs, and store scope rules.

3.3 0.3 Scan Configuration & Execution

This module manages the configuration and execution of vulnerability scans. It checks whether the selected scan settings are valid, verifies user limits, schedules scan jobs, and keeps track of each stage of the scan.

- **Functions:** Validate scan profiles and quotas, queue or schedule scan jobs, manage scan execution and checkpoints, and store information required to reproduce a scan.

3.4 0.4 Discovery (Crawling)

This module explores the authorised website to identify possible attack surfaces such as links, forms, API endpoints, and dynamically generated JavaScript content. The crawler follows the limits and scope defined for the scan.

- **Functions:**
Load scope and crawling limits, discover links and sitemap entries, render JavaScript content, remove duplicate results, and send candidates to the Scope Guard for validation.

3.5 0.5 Vulnerability Detection

This module checks the discovered website components for security weaknesses. It performs passive checks on responses and headers, carries out safe active tests only on authorised targets, and uses external security databases to identify known vulnerabilities.

- **Functions:** Perform passive response checks, prepare safe active vulnerability tests, and check component versions using OSV and EPSS APIs.

3.6 0.6 Findings Management

This module processes the raw results produced during a scan and converts them into clear findings. It removes or hides sensitive information, compares findings with previous scans, and organises the results based on their severity and status.

- **Functions:** Normalise and redact findings, compare results with previous scan evidence, apply triage rules, filter findings, and sort them by severity.

3.7 0.7 Reporting & Export

This module converts completed scan results into readable reports for both technical and non-technical users. It also supports exporting scan information and notifying users when a scan is complete.

- **Functions:** Select completed scans, prepare report templates and supporting evidence, generate PDF or CSV exports and share links, and send completion notifications through SMTP.

3.8 0.8 Safety, Auditing & Administration

This module ensures that scans remain within the approved scope and follow the required safety rules. It checks target verification, blocks restricted destinations, re-checks IP addresses to reduce SSRF and TOCTOU risks, limits request rates, and records scanning activity for auditing.

- **Functions:** Verify target authorisation and scope blocklists, re-resolve IP addresses, apply rate limits, send approved requests, and maintain an append-only audit log.

4 Structure Charts

4.1 Level 1 Structure Chart

4.1.1 Module Decomposition

The structure chart is derived from the Level 1 and Level 2 DFDs using the structured design approach of Rajib Mall. The user-facing request routing is factored by transaction analysis into one action module per transaction path, and the scan pipeline (0.3 $\rightarrow$ 0.4 $\rightarrow$ 0.5 $\rightarrow$ 0.6) is factored by transform analysis into an afferent branch, a transform centre, and an efferent branch. The Scope Guard modules (0.8) appear as shared library modules, with control couples (dotted arrows) carrying decisions such as approved/refused and lockout. Figure 11 illustrates the resulting module hierarchy.

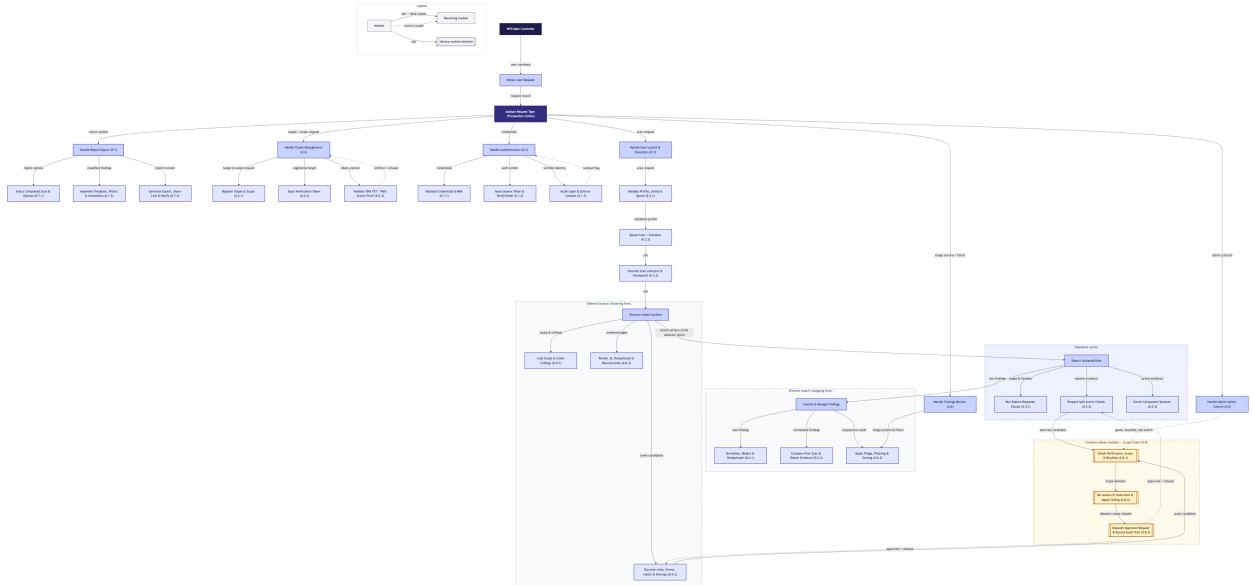


Figure 11: Level 1 Structure Chart of the System